

PENETRATION TESTING AND ESSENTIAL EIGHT REMEDIATION

Authorised Security Assessment & Defensive Hardening Report – Isolated Lab Environment

Author: Nathan | University Student (IT/Cybersecurity) | Perth, Western Australia

Prepared for: ADF RAAF Cyber Warfare Officer Application Portfolio

Associated Activity: AAFC 721 Squadron (WA) Cadet Application & Skills Development

Date of Assessment: 4 July 2026

EXECUTIVE SUMMARY

This report documents a structured, authorised penetration test conducted against an isolated multi-VM cybersecurity home laboratory environment, followed by comprehensive remediation actions explicitly mapped to the Australian Signals Directorate (ASD) Essential Eight mitigation strategies. The assessment was performed from a dedicated attacker platform (Kali Linux) against intentionally vulnerable targets and domain-joined assets within a segmented network architecture.

The primary objectives were to identify exploitable vulnerabilities, demonstrate realistic attack paths an adversary could take, quantify business and operational risk, and then implement and validate defensive controls aligned with national cyber security frameworks. All activities were conducted ethically within a controlled, snapshot-enabled virtual environment with no impact on production systems.

Key findings included a critical vsftpd backdoor, weak SMB authentication, multiple web application vulnerabilities (SQL injection and unrestricted file upload), and several Windows configuration weaknesses. Each finding was exploited to demonstrate impact, then fully remediated through patching, Group Policy changes, application control, and hardening. Post-remediation re-testing confirmed that previously successful attack paths were blocked or significantly mitigated. This work provides direct, evidence-based demonstration of both offensive security understanding and defensive implementation capability aligned with the responsibilities of a RAAF Cyber Warfare Officer.

1. INTRODUCTION, SCOPE AND RULES OF ENGAGEMENT

The Royal Australian Air Force (RAAF) Cyber Warfare Officer role requires personnel who can understand adversary techniques, assess risk to networks and information systems, and implement robust defensive controls in accordance with ASD frameworks. This assessment directly exercises those capabilities in a safe, repeatable lab environment that mirrors elements of protected ADF networks.

Rules of Engagement (RoE): Testing was strictly limited to the isolated lab virtual machines. No internet-facing systems, third-party assets, or production environments were targeted. All activities were logged, and snapshots were taken before and after major changes to ensure complete reversibility. The assessment was performed by the author as part of a personal cybersecurity portfolio development program in preparation for AAFC 721 Squadron cadet application and future ADF enlistment.

Scope: All virtual machines in the lab environment (pfSense firewall, Windows Server 2022 Domain Controller, Windows 10 client, Metasploitable 3 target, and Kali Linux attacker). Testing included network reconnaissance, service enumeration, vulnerability identification, exploitation, post-exploitation, and impact assessment. Remediation and re-testing phases were included to demonstrate the full defensive lifecycle.

2. DETAILED METHODOLOGY AND PRACTICAL STEPS TAKEN

2.1 Planning and Scoping

A formal one-page Rules of Engagement document was created and saved as RoE_Pentest_2026-07-04.md. It defined authorised targets (all lab IPs), prohibited actions (denial of service, destructive attacks, or actions outside the lab), success criteria (full technical report + verified remediations), and communication requirements. The scope was intentionally limited to the DMZ and internal protected subnets to simulate a realistic internal network assessment an adversary might achieve after initial foothold.

2.2 Reconnaissance and Discovery

From the Kali Linux attacker VM (192.168.30.50), the following commands were executed:

- Host discovery: `nmap -sn 192.168.0.0/16` — identified all live hosts across subnets.
- Service and OS enumeration (DMZ target): `nmap -sV -sC -O -p- --script vuln 192.168.20.100` — revealed vsftpd 2.3.4 backdoor, Samba, Apache, SSH, and multiple vulnerabilities.
- SMB enumeration (Windows assets): `nmap --script smb-enum-shares,smb-enum-users -p 445 192.168.10.0/24` — identified null session and weak credential possibilities on the domain controller and client.

All output was captured, timestamped, and logged for the final report. This phase established the attack surface and prioritised targets based on exposed services and known vulnerabilities.

2.3 Vulnerability Assessment and Exploitation

Finding PT-01 – Critical: vsftpd 2.3.4 Backdoor

Exploitation steps: Launched Metasploit Framework → use exploit/unix/ftp/vsftpd_234_backdoor → set RHOSTS 192.168.20.100 → exploit. A root shell was obtained within seconds. Post-exploitation: verified root access, listed /etc/shadow, and demonstrated ability to pivot.

Finding PT-02 – High: Weak SMB Credentials & Null Session

Used Metasploit auxiliary module auxiliary/scanner/smb/smb_login with a custom wordlist. Successfully authenticated to the Domain Controller with a weak local account. Subsequently used crackmapexec and manual enumeration to map shares and users. Demonstrated potential for lateral movement and credential harvesting.

Finding PT-03 – High: DVWA SQL Injection + Unrestricted File Upload

Manual testing via browser and Burp-style interception: bypassed login using classic SQLi payload ' or '1'='1. Uploaded a PHP webshell via the file upload vulnerability. Executed commands on the target, established a reverse shell back to Kali, and demonstrated data exfiltration capability (fake sensitive document created and downloaded).

2.4 Post-Exploitation and Impact Demonstration

From the obtained shells, several post-exploitation actions were performed to illustrate business/operational impact: process migration, screenshot of desktop, hash dumping (where possible), and simulated data exfiltration of a planted “sensitive” file. These steps quantified the risk beyond simple shell access — showing potential for persistence, credential theft, and data breach.

2.5 Reporting

A professional technical report was authored with Executive Summary (suitable for non-technical leadership), detailed technical findings (with reproduction steps, screenshots, risk ratings using CVSS-style scoring, and business impact), and clear remediation recommendations. The report structure followed industry standards for ADF/government consumption.

3. REMEDIATION AND ESSENTIAL EIGHT MAPPING

Each finding was addressed with specific, verifiable controls mapped directly to the Essential Eight. After remediation, the exact same attack techniques were re-executed to confirm mitigation.

Finding	Risk	Essential Eight Remediation Applied	Validation Result
vsftpd 2.3.4 backdoor	Critical	Patch Applications + Application Control (removed vulnerable package; AppLocker rules on any Windows assets)	Exploit module failed; service no longer present
Weak SMB / Null Session	High	Restrict Administrative Privileges (GPO: remove unnecessary local admins, enforce strong passwords, account lockout); enabled SMB signing	Null session blocked; brute-force attempts logged and locked out
DVWA SQLi + File Upload	High	User Application Hardening + input validation/sanitisation (replaced vulnerable code with prepared statements and file type/size restrictions); App Control	Injection payloads sanitised; upload of .php blocked

Table 1: Key Findings, Risk, Essential Eight Remediation, and Post-Remediation Validation

All remediations were implemented via Group Policy where possible for centralised, auditable control — a model directly transferable to ADF enterprise environments.

4. LESSONS LEARNED AND ADF RELEVANCE

This assessment reinforced several operationally relevant lessons:

- **Exploitation provides irreplaceable insight:** Successfully compromising a target and then hardening it creates deep understanding of both attacker tradecraft and effective defensive controls — far more valuable than theory alone.
- **Remediation is harder than exploitation:** Implementing fixes without breaking legitimate functionality, and then proving the fix with re-testing, is the real defensive skill.
- **Documentation and evidence matter:** Producing a clear, professional report with reproduction steps, risk ratings, and validated remediations is essential for leadership decision-making and audit — exactly what is expected in ADF cyber roles.
- **Essential Eight is actionable:** Every control in the framework has direct, practical application in a lab (and by extension in operational) environments.

These capabilities — understanding adversary techniques, assessing and communicating risk, implementing and validating controls aligned with national frameworks — map directly to the core responsibilities of a Cyber Warfare Officer responsible for protecting ADF networks, data, and information systems.

5. CONCLUSION

This authorised penetration test and remediation exercise successfully identified, exploited, documented, and mitigated multiple high-risk vulnerabilities in a controlled lab environment. All findings were addressed with verifiable Essential Eight controls, and post-remediation testing confirmed improved security posture. The work provides strong, practical evidence of both offensive security understanding and defensive implementation skill — directly relevant to RAAF Cyber Warfare Officer selection and future operational effectiveness. The artefacts (detailed report, screenshots, reproduction steps, and validation evidence) form a core component of the author's ADF application portfolio.

References: ASD Essential Eight (cyber.gov.au), ISM, Metasploit Framework documentation, Nmap documentation, Microsoft Security Baselines & Group Policy guidance.